

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Port Scanning Challenge

1. How would you identify and prioritize vulnerabilities after discovering multiple open ports during a port scan? Explain your approach.
 2. A SYN scan and a TCP Connect scan produce different results on the same target. What factors could cause this difference, and how would you verify the findings?
 3. During a port scan, most ports appear as "filtered." What security mechanisms might be responsible, and what additional techniques would you use to gather more information?
 4. Compare TCP, UDP, and stealth (SYN) port scanning techniques. In which scenarios would each be the most effective, and what are their advantages and limitations?
 5. Suppose you are conducting an authorized security assessment and discover critical services (such as SSH, FTP, and database ports) exposed to the internet. How would you assess the risks and recommend mitigation strategies?
-

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

1. Identifying and prioritizing vulnerabilities after discovering multiple open ports

I would follow a risk-based approach:

Identify the services running on each open port using service/version detection.

Determine the purpose of each service and whether it is actually required.

Check for known vulnerabilities associated with the detected software versions.

Assess exposure — internet-facing services generally receive higher priority than internal-only services.

Evaluate severity using factors such as CVSS score, exploit availability, authentication requirements, and potential impact.

Prioritize critical weaknesses first, especially vulnerabilities that allow remote code execution, authentication bypass, or unauthorized access.

Validate important findings to reduce false positives before reporting them.

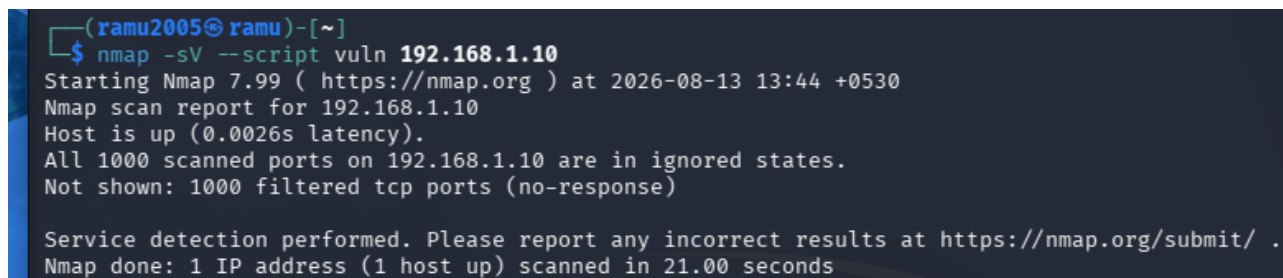
Recommend remediation, such as patching, disabling unnecessary services, restricting access, or improving authentication.

Priority example:

Internet-facing database with a known critical vulnerability → Critical

Outdated SSH with weak configuration → High

Unnecessary HTTP service with low-risk information disclosure → Medium/Low



```
(ramu2005@ramu)-[~]
$ nmap -sV --script vuln 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 13:44 +0530
Nmap scan report for 192.168.1.10
Host is up (0.0026s latency).
All 1000 scanned ports on 192.168.1.10 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.00 seconds
```

2. SYN scan vs TCP Connect scan producing different results

Several factors can cause different results:

Firewall filtering: A firewall may treat SYN packets differently from completed TCP connections.

Intrusion Detection/Prevention Systems: IDS/IPS devices may detect and block SYN scans.

TCP wrappers or host-based firewalls: The operating system may respond differently depending on the connection method.

Network instability: Packet loss or latency can produce inconsistent results.

Rate limiting: The target may temporarily block or delay repeated connections.

Service behavior: Some applications respond differently to incomplete and completed connections.

Scan timing: Running the scans at different times can produce different results.

Verification approach:

Repeat both scans with appropriate timing.

Compare results across multiple scans.

Perform service/version detection on confirmed open ports.

Examine firewall/IDS logs when authorized.

Check the target locally if access is available.

Use packet capture such as Wireshark to determine how SYN, SYN/ACK, RST, and other packets are being handled.

```
(ramu2005@ramu)-[~]
$ nmap -sS -p 1-1000 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 13:51 +0530
Nmap scan report for 192.168.1.10
Host is up (0.00080s latency).
All 1000 scanned ports on 192.168.1.10 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 8.37 seconds
```

```
(ramu2005@ramu)-[~]
$ nmap -sT -p 1-1000 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 13:51 +0530
Nmap scan report for 192.168.1.10
Host is up (0.0022s latency).
All 1000 scanned ports on 192.168.1.10 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 30.10 seconds
```

3. Most ports appear as "filtered"

A filtered result generally means the scanner cannot determine whether the port is open because packets are being blocked or dropped.

Possible security mechanisms include:

- Network firewalls
- Host-based firewalls
- ACLs on routers
- IDS/IPS systems
- Cloud security groups
- Network segmentation
- Rate limiting
- Packet filtering that silently drops probes

Additional information-gathering techniques during an authorized assessment include:

- Checking firewall and IDS/IPS logs
- Performing scans from an approved internal location
- Comparing results from different network segments
- Using appropriate TCP and UDP probes
- Performing service/version detection where ports are confirmed accessible
- Checking DNS records and other authorized asset information
- Capturing network traffic to understand how packets are being filtered

The objective should be to understand the filtering mechanism, not simply to bypass security controls without authorization.

```
(ramu2005@ramu)-[~]
$ nmap -sS -p- 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 13:53 +0530
Stats: 0:01:51 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 45.32% done; ETC: 13:57 (0:02:09 remaining)
Stats: 0:02:54 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 73.03% done; ETC: 13:57 (0:01:03 remaining)
Nmap scan report for 192.168.1.10
Host is up (0.13s latency).
All 65535 scanned ports on 192.168.1.10 are in ignored states.
Not shown: 65535 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 235.24 seconds
```

4. Compare TCP, UDP, and Stealth (SYN) Port Scanning Techniques

TCP Connect Scan:

TCP Connect scanning establishes a complete TCP connection with the target port using the three-way handshake. It is useful when a full connection is required or when SYN scanning is not available. It is reliable and easy to perform, but it is more noticeable because the connection is fully established and may be recorded in application logs.

UDP Scan:

UDP scanning sends UDP packets to the target ports and analyzes the responses. It is mainly useful for discovering UDP-based services such as DNS, DHCP, and SNMP. Its major advantage is that it can identify services that TCP scans cannot detect. However, UDP scanning is generally slower, and many UDP ports may not respond, making the results more difficult to interpret.

Stealth (SYN) Scan:

A SYN scan sends a TCP SYN packet and analyzes the response without completing the full TCP connection. A SYN/ACK usually indicates an open port, while an RST indicates a closed port. It is commonly used because it is faster and generates less application-level activity than a TCP Connect scan. However, it can still be detected by firewalls and IDS/IPS systems and generally requires appropriate privileges.

Comparison:

TCP Connect scanning is suitable when reliability and complete connections are needed. UDP scanning is essential for identifying UDP services. SYN scanning is generally effective for quickly identifying TCP ports during an authorized security assessment because it is efficient and does not normally complete the TCP handshake.

```
ramu2005@ramu: ~  
Session Actions Edit View Help  
[ramu2005@ramu]~  
$ nmap -sT -p 1-1000 192.168.1.10  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:10 +0530  
Nmap scan report for 192.168.1.10  
Host is up (0.0011s latency).  
Not shown: 995 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
Nmap done: 1 IP address (1 host up) scanned in 2.91 seconds  
[ramu2005@ramu]~  
$ sudo nmap -sU --top-ports 100 192.168.1.10  
[sudo] password for ramu2005:  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:11 +0530  
Nmap scan report for 192.168.1.10  
Host is up (0.0013s latency).  
Not shown: 98 open|filtered udp ports (no-response)  
PORT      STATE SERVICE  
53/udp    open|filtered domain  
161/udp   open|filtered snmp  
Nmap done: 1 IP address (1 host up) scanned in 30.47 seconds  
[ramu2005@ramu]~  
$ sudo nmap -sS -p 1-1000 192.168.1.10  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:11 +0530  
Nmap scan report for 192.168.1.10  
Host is up (0.00042s latency).  
Not shown: 997 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
139/tcp   open  netbios-ssn  
Nmap done: 1 IP address (1 host up) scanned in 2.66 seconds  
[ramu2005@ramu]~  
$ nmap -sV -p 1-1000 192.168.1.10  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:12 +0530  
Nmap scan report for 192.168.1.10  
Host is up (0.0010s latency).  
PORT      STATE SERVICE      VERSION  
22/tcp    open  ssh          OpenSSH 7.9 (protocol 2.0)  
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))  
139/tcp   open  netbios-ssn  Samba smbd 4.10.3 (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 4.10.3 (workgroup: WORKGROUP)  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 9.72 seconds  
[ramu2005@ramu]~  
$
```

5. Assessing exposed SSH, FTP, and database services

I would assess each exposed service according to exposure, configuration, vulnerability, authentication, and business impact.

SSH:

- Determine the SSH version and configuration.
- Check whether outdated software is being used.
- Review authentication methods.
- Check whether password authentication is unnecessarily enabled.
- Restrict SSH access to trusted networks or VPN where possible.
- Use strong authentication and preferably key-based authentication.
- Apply security updates.

FTP:

- Determine whether FTP is actually required.
- Check whether anonymous access is enabled.
- Determine whether credentials or data are transmitted without encryption.
- Replace plain FTP with a secure alternative such as SFTP where appropriate.
- Restrict access and disable the service if it is unnecessary.

Database ports:

- Determine the database type and version.
- Check whether the database genuinely needs to be internet-accessible.
- Restrict access using firewall rules, VPNs, or allowlists.
- Enforce strong authentication and least privilege.
- Patch the database software.
- Monitor authentication attempts and unusual activity.
- Recommended priority

Critical: Internet-facing service with a known exploitable critical vulnerability or unauthorized access possibility.

High: Directly exposed database, insecure FTP configuration, outdated SSH, or weak authentication.

Medium: Unnecessary service exposure or configuration weaknesses without an immediate exploit path.

Low: Minor information disclosure or hardening opportunities.

```
(ramu2005@ramu)-[~]
$ nmap -sV -p 22,21,3306 203.0.113.50
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:04 +0530
Nmap scan report for 203.0.113.50
Host is up (0.0086s latency).

PORT      STATE      SERVICE VERSION
21/tcp    filtered  ftp
22/tcp    filtered  ssh
3306/tcp   filtered  mysql

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.97 seconds

(ramu2005@ramu)-[~]
```

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Identification of Port Scanning Factors	25%	Clearly identifies comprehensive and relevant strengths, weaknesses, opportunities, and threats	Identifies most factors with minor gaps	Limited or partially relevant identification	Incorrect or incomplete Port Scanning factors
Analysis	25%	Provides deep, insightful analysis of each Port Scanning component with strong reasoning	Provides good analysis with some depth	Basic analysis with limited reasoning	No meaningful analysis provided
Linkage	20%	Effectively links Port Scanning elements to derive strong strategic insights and implications	Shows some linkage with moderate insights	Weak linkage; limited strategic thinking	No linkage or strategic insight
Application	20%	Applies Port Scanning analysis effectively to the given case or scenario with clear relevance	Applies analysis with minor gaps	Limited application; lacks clarity	No clear application to context
Clarity	10%	Well-structured, clear, and logically presented with proper formatting	Generally clear with minor issues	Some structure but lacks clarity	Poorly organized and difficult to understand